

VujaDe Platform: Issues and Improvements Log

This document details all identified issues, security vulnerabilities, and recommended improvements for the VujaDe Platform, intended for the development team.

1. Critical Security Vulnerabilities

1.1. Insecure Direct Object Reference (IDOR) - Cross-Client Project Access

- **Severity:** Critical
- **Description:** A client user can access other clients' project details by manually changing the project ID in the URL. This exposes sensitive project information across different client accounts.
- **Affected Persona(s):** Client (John Client, Alex Rivera, Sam Chen)
- **Steps to Reproduce:**
 1. Log in as `client@vujade.com` (John Client).
 2. Navigate to a known project URL, e.g., `https://portal.vujadesa.com/projects/show/1`.
 3. Manually change the project ID in the URL to another existing project ID, e.g., `https://portal.vujadesa.com/projects/show/2` (which belongs to Alex Rivera).
 4. **Expected Result:** Access denied or redirection to own projects.
 5. **Actual Result:** The client can view the details of another client's project.
- **Recommended Fix:** Implement robust authorization checks (e.g., using middleware) on all project-related endpoints to ensure that only the project owner or authorized internal users can access specific project data. Consider using UUIDs instead of sequential IDs for URLs.

1.2. Employee Access to Manager-Level Pricing Admin

- **Severity:** High
- **Description:** An employee user can access the 'Pricing Admin' page, which should be restricted to managers, by directly navigating to its URL.
- **Affected Persona(s):** Employee (Sarah Employee, Jordan Internal)
- **Steps to Reproduce:**

1. Log in as `employee@vujade.com` (Sarah Employee).
 2. Navigate directly to the URL: `https://portal.vujadesa.com/internal/pricing-admin` .
 3. **Expected Result:** Access denied or redirection to employee dashboard.
 4. **Actual Result:** The employee gains access to the Pricing Admin page.
- **Recommended Fix:** Implement server-side role-based access control (RBAC) for all internal administration routes. Ensure that only users with the 'Manager' role can access `/internal/pricing-admin` .

1.3. Client Access to Internal Dashboard

- **Severity:** High
 - **Description:** A client user can access the internal dashboard by directly navigating to its URL after logging in.
 - **Affected Persona(s):** Client (John Client)
 - **Steps to Reproduce:**
 1. Log in as `client@vujade.com` (John Client).
 2. Navigate directly to the URL: `https://portal.vujadesa.com/internal` .
 3. **Expected Result:** Access denied or redirection to client dashboard.
 4. **Actual Result:** The client is redirected to the login page, but after re-logging in, they are redirected to the internal dashboard. This indicates a session management or redirection logic flaw.
 - **Recommended Fix:** Ensure that after successful login, users are always redirected to their role-specific dashboard. Implement strict role-based routing and prevent clients from accessing any `/internal` routes.
-

2. Functional Issues

2.1. Missing Visual Feedback for Quote Approval

- **Severity:** Medium
- **Description:** When a client approves a quote, there is no clear visual confirmation (e.g., a success message or toast notification) that the action was successful. The page simply reloads.
- **Affected Persona(s):** Client (John Client)
- **Steps to Reproduce:**

1. Log in as `client@vujade.com` (John Client).
 2. Navigate to a project with a quote in 'Negotiation' status, e.g., `https://portal.vujadesa.com/client/ideas/1` .
 3. Click the 'Approve Quote' button.
 4. **Expected Result:** A success message (e.g., "Quote approved successfully!") appears, and the status updates.
 5. **Actual Result:** The page reloads, and the status updates, but no explicit success message is displayed, potentially leading to user confusion.
- **Recommended Fix:** Implement a client-side notification system (e.g., using a toast library) to display clear success messages after critical actions like quote approval.

2.2. Broken Logout Link/Redirection

- **Severity:** Low
- **Description:** Occasionally, navigating directly to the logout URL or clicking the logout button can result in a 404 error or an unexpected redirection loop.
- **Affected Persona(s):** All
- **Steps to Reproduce:**
 1. Log in with any user account.
 2. Click the 'Logout' button in the sidebar.
 3. Alternatively, navigate directly to `https://portal.vujadesa.com/logout` .
 4. **Expected Result:** User is successfully logged out and redirected to the login page.
 5. **Actual Result:** Sometimes, a 404 page is displayed, or the user is redirected to an incorrect page before finally landing on the login page.
- **Recommended Fix:** Review the logout route and redirection logic to ensure consistent and correct behavior across all scenarios. Ensure proper session invalidation and redirection to `/login` .

3. User Experience (UX) & Minor Issues

3.1. Technical Error Messages Displayed to Users

- **Severity:** Low
- **Description:** Some error messages displayed to the user are technical (e.g., "Request failed with 500"), which are not user-friendly and do not provide actionable information.

- **Affected Persona(s):** All
- **Steps to Reproduce:** (Requires triggering a server-side error, e.g., by submitting malformed data or accessing a non-existent resource in specific scenarios).
 1. Attempt to upload a file with an invalid extension.
 2. **Expected Result:** A user-friendly error message, e.g., "Invalid file type. Please upload PDF or image files."
 3. **Actual Result:** A generic or technical error message is displayed.
- **Recommended Fix:** Implement custom error pages and user-friendly error messages for all common error scenarios. Log technical details internally but present simplified, actionable information to the user.

4. Recommended Improvements

Category	Improvement	Priority
Security	Encrypt or obfuscate IDs in URLs to prevent IDOR attacks.	High
Security	Implement strict server-side role-based access control (RBAC) for all sensitive routes and data.	High
UX	Add interactive success/error notifications (toasts/alerts) for user actions.	Medium
UX	Enhance error message handling to display user-friendly messages instead of technical ones.	Medium
Performance	Optimize image loading and asset delivery for faster page load times (if not already done).	Low
General	Conduct regular security audits and penetration testing.	Ongoing

Prepared by: QA Expert Date: May 08, 2026